

04a — REST APIs

Key Concepts

Term	Definition
REST	Representational State Transfer — architectural style for APIs over HTTP
Stateless	Server holds no session — every request carries its own auth/context
Resource	A noun that an API exposes — users, orders, products
Endpoint	A URL + HTTP method combination
Status Code	Numeric code in the response indicating outcome

The 6 REST Constraints

Constraint	Meaning
Client-Server	UI and backend are separate, communicate only via API
Stateless	Server stores no session — each request is self-contained
Cacheable	Responses can be cached
Uniform Interface	Consistent URL structure and HTTP methods
Layered System	Client doesn't know if it's hitting the real server or a proxy
Code on Demand	(Optional) Server can send executable code

HTTP Methods

Method	Action	Example
GET	Read	GET /users/1
POST	Create	POST /users
PUT	Replace fully	PUT /users/1
PATCH	Partial update	PATCH /users/1
DELETE	Remove	DELETE /users/1

URL Design — Nouns Not Verbs

Bad:	GET /getUser/1	Good: GET /users/1
Bad:	POST /createUser	Good: POST /users

```
Bad:  POST /deleteUser/1    Good: DELETE /users/1
Bad:  POST /getUserOrders   Good: GET /users/1/orders
```

Status Codes

Code	Meaning	When
200	OK	Successful GET, PUT, PATCH
201	Created	Successful POST
204	No Content	Successful DELETE
400	Bad Request	Invalid client input
401	Unauthorized	Not authenticated — "who are you?"
403	Forbidden	Authenticated but not permitted — "you can't do this"
404	Not Found	Resource doesn't exist
409	Conflict	Duplicate resource
422	Unprocessable Entity	Validation failed
500	Internal Server Error	Server-side bug

401 vs 403: 401 = identity unknown. 403 = identity known, access denied.

Best Practices

- **Version your API:** `/v1/users`, `/v2/users` — prevents breaking existing clients
 - **Paginate responses:** `?page=1&limit=20` — never return unbounded lists
 - **Consistent error format:** `{ "error": "user_not_found", "message": "..."}`
 - **Always use HTTPS**
-

Industry Examples

Company	Usage
Stripe	Gold standard REST design — clean URLs, versioned, consistent errors
GitHub API	Fully RESTful — <code>GET /repos/{owner}/{repo}</code>
Twilio	REST API for SMS/calls

Interview Questions

Q: What makes an API RESTful? A: It follows REST constraints — stateless, uniform interface (nouns not verbs), uses HTTP methods correctly, client-server separation.

Q: What is the difference between PUT and PATCH? A: PUT replaces the entire resource. PATCH updates only the specified fields.

Q: What is the difference between 401 and 403? A: 401 means unauthenticated — server doesn't know who you are. 403 means unauthorized — server knows who you are but you don't have permission.

Q: Why is REST stateless and why does that matter? A: Server holds no session state — every request carries its own context (e.g. JWT). This makes the API horizontally scalable — any server can handle any request.